

Incident Response Checklist

A first-72-hours checklist for detecting, containing, and communicating during a security incident. Print it, laminate it, or pin it somewhere your team can find it under pressure.

First 60 Minutes — Detect & Triage

- ☐ Confirm the incident is real and not a false positive.
- ☐ Assign an incident commander to own coordination and decisions.
- ☐ Establish a dedicated communication channel isolated from potentially compromised systems.
- ☐ Begin a timeline log capturing every action, decision, and observation with timestamps.
- ☐ Identify affected systems, accounts, and data at a high level.
- ☐ Determine initial severity and activate the appropriate response tier.
- ☐ Notify key internal stakeholders (leadership, legal, IT) per the response plan.

Hours 1-24 — Contain

- ☐ Isolate affected systems from the network without powering them off, to preserve volatile evidence.
- ☐ Disable or reset credentials for compromised or suspected accounts.
- ☐ Revoke active sessions and tokens for affected identities.
- ☐ Block known malicious IPs, domains, or indicators at the network and email gateway.
- ☐ Preserve forensic evidence (memory captures, disk images, logs) before remediation alters systems.
- ☐ Engage external incident response or legal counsel if scope or severity warrants it.
- ☐ Determine whether regulatory or contractual notification clocks have started.

Hours 24-72 — Eradicate & Recover

- ☐ Identify and remove the root cause (malware, unauthorized access, vulnerability) from all affected systems.
- ☐ Patch or reconfigure the exploited vulnerability or misconfiguration.
- ☐ Rebuild or restore affected systems from known-clean backups where possible.
- ☐ Rotate all credentials and secrets that may have been exposed.
- ☐ Validate systems are clean before reconnecting them to the network.
- ☐ Monitor closely for signs of persistence or re-compromise post-recovery.
- ☐ Begin drafting the incident timeline and impact summary for stakeholders.

Communication (Throughout)

- ☐ Provide regular status updates to leadership on a defined cadence (every 2-4 hours during active response).
- ☐ Prepare customer/partner notification language in coordination with legal, if data was affected.
- ☐ Coordinate with legal counsel on regulatory notification obligations and deadlines.
- ☐ Avoid speculative public statements before facts are confirmed.
- ☐ Document all communications sent, to whom, and when.